# The GDPR For Indie Hackers Playbook

A 22-page field guide to shipping a GDPR-compliant SaaS as a solo founder or tiny team, without hiring a DPO, paying $20k to a law firm, or blocking your launch in the EU.

**Who this is for:** founders shipping a SaaS product who want to sell to EU customers without getting fined 4% of revenue. You are not a lawyer. You don't need to become one. You need a practical playbook that holds up to a real audit.

**What this is not:** a 200-page legal treatise on the General Data Protection Regulation. This is the minimum viable compliance program that keeps you out of trouble and lets you close EU deals.

---

## Chapter 1 -- Why GDPR is a moat, not a tax

Most indie hackers treat GDPR like an obligation: something bigcos do to avoid EU fines. The opposite is true for SaaS. Done well, GDPR compliance is the reason an EU enterprise will choose your product over a US competitor who can't sign a Data Processing Agreement. Done badly, it is the reason your EU Stripe payouts get frozen after a single complaint.

The reason: every EU customer, every B2B contract with an EU counterparty, and every EU-based VC requires documented GDPR compliance. They want a DPA (Data Processing Agreement). They want to know where the data is stored. They want to know how you handle deletion requests. If your answer is "we'll add it later," you don't get the contract. If your answer is "here's our DPA, our data flow diagram, and our 30-day deletion SLA," you close.

The hard part is that this compliance is hard to fake. You either have the documentation, the processes, and the discipline, or you don't, and your EU revenue will reflect that within two quarters.

This playbook is about the discipline. Specifically, the minimum viable version of it that holds up to a real audit and unblocks EU revenue. The framework underneath is GDPR's seven principles (Article 5) plus the lawful bases for processing (Article 6) plus the data subject rights (Articles 15-22). You don't need to memorize these. You need to satisfy them in your product and your contracts.

By the end of this book, you will have a 30-day plan to ship a GDPR-compliant SaaS that holds up to a real audit.

---

## Chapter 2 -- The six documents every SaaS must have

You need six documents. Not 60. Six. Every enterprise customer, every DPA negotiation, and every privacy regulator inquiry will pull from these same six files. Build them once, keep them current, and reuse them forever.

**1. Privacy Policy.** A public page on your website that explains what data you collect, why, how long you keep it, who you share it with, and how users can request deletion, export, and correction. Don't write from scratch. Use a generator like `iubenda.com` ($27/yr) or `termly.io` ($120/yr) and customize. Required by GDPR, CCPA, and most App Store review processes.

**2. Data Processing Agreement (DPA).** A contract between you and any customer who is a "data controller" (i.e., their users' data flows through your system). Required by GDPR Article 28. The minimum: scope of processing, duration, nature of data, obligations of each party, sub-processor list. Don't write from scratch. Most compliance platforms (see Chapter 3) include a standard DPA you can use.

**3. Data Flow Diagram.** One page. Shows where customer data enters your system, where it's stored, where it's processed, where it leaves, and who has access. The minimum: a draw.io diagram with boxes for your database, your background workers, your third-party APIs (Stripe, OpenAI, etc.), and arrows showing data flow. Auditors ask for this in every DPA negotiation.

**4. Record of Processing Activities (ROPA).** A spreadsheet listing every category of data you process, the lawful basis for each (consent, contract, legitimate interest, etc.), the retention period, and the security measures. Required by GDPR Article 30 for any company processing personal data. Most SaaS companies maintain this in a Notion database.

**5. Sub-processor list.** A public page listing every third party that processes customer data on your behalf (AWS, Stripe, OpenAI, your email tool, your analytics tool). Each one needs its own DPA. The list changes as you add vendors. Update it within 30 days of adding a new sub-processor (some customer contracts require this).

**6. Breach response runbook.** A 1-page document: who to call, who tells customers, who tells the regulator (you have 72 hours under GDPR), and what the customer notification template looks like. Required by GDPR Article 33. The runbook only matters the day you have a breach. The auditor wants to know it exists before that day.

You can have all six in two weeks. Most indie hackers take 3 months because they overthink the legal language. Use the templates in Appendix A. Done is better than perfect.

---

## Chapter 3 -- The 30-day plan to ship GDPR compliance

The plan is deliberately small. If you can't do 30 days of this, you can't do GDPR at all and should not be selling to EU customers.

**Week 1 -- Privacy Policy + DPA.** Generate the Privacy Policy (iubenda, termly) and customize the DPA from a template. Both are 90-minute tasks. Publish the Privacy Policy on your site. Save the DPA as a PDF in your contracts folder.

**Week 2 -- Data Flow Diagram + ROPA.** Draw the diagram in draw.io. Walk through your codebase and list every database table, every third-party API, every background job. The ROPA is a spreadsheet with one row per data category. Both are half-day tasks.

**Week 3 -- Sub-processor DPAs + Breach Runbook.** For each third-party processor, find their standard DPA (AWS, Stripe, OpenAI, etc. all have them publicly available) and save them in a folder. Write the breach runbook as a one-pager. Add a public page listing your sub-processors (your customers will ask for this).

**Week 4 -- Test the program.** Pick your largest EU customer (or your most likely EU customer persona). Send them your Privacy Policy, DPA, and data flow diagram. Ask them to flag any concerns. If they don't push back, the program is enough. If they do, you now have a real list of fixes.

The output of week 4 is a real, audit-ready GDPR program. It will not be perfect. It will be enough.

---

## Chapter 4 -- The four things that will get you in trouble

These are the patterns I've seen get indie hackers into actual trouble with EU data protection authorities. They are all preventable.

**1. Using US-based vendors without DPAs.** If you store EU customer data in US AWS regions and don't have a DPA with AWS (you do by default, check your AWS console), or if you use a US-based vendor that doesn't have a DPA, you're in violation. The fix: every vendor that touches personal data needs a signed DPA. AWS, Stripe, OpenAI, Cloudflare, and most enterprise vendors have standard DPAs available immediately.

**2. No deletion endpoint.** GDPR Article 17 gives users the right to be forgotten. If a user emails you asking to delete their account and you can't do it within 30 days, you're in violation. The fix: a `DELETE /api/users/{id}` endpoint that actually deletes from your production database, your analytics warehouse, your backups (eventually), and your third-party processors.

**3. Cookie banner that doesn't work.** The cookie consent requirements are real. If you have Google Analytics or any non-essential cookie set before consent, you're in violation. The EU has fined companies for this repeatedly. The fix: a proper consent management platform (Cookiebot, $12/month, or Osano). Don't roll your own.

**4. Marketing emails without consent.** GDPR requires explicit opt-in for marketing emails (versus US CAN-SPAM which allows opt-out). If you email EU users who didn't check a box saying "yes, send me marketing," you're in violation. The fix: double opt-in for EU users, or segment by signup source. Mailchimp and ConvertKit both handle this if you configure them.

---

## Chapter 5 -- The program that compounds after the first audit

After the 30-day plan, you have the six documents and a working process. The next 12 months are about making it a habit, not a one-time project.

**Quarter 1 post-launch -- Embed the documentation.** Add "data flow updated" to your quarterly review. Add the deletion endpoint to your standard user-deletion workflow. Add the sub-processor DPA check to your

vendor onboarding workflow. None of this is hard. It's the same control, surfaced at the moment it's needed.

**Quarter 2 -- Annual ROPA review.** Walk through the ROPA. Has anything changed? New data category? New vendor? Update it. Auditors will ask "when was the ROPA last reviewed?" and "current quarter" is the right answer.

**Quarter 3 -- Quarterly access reviews.** Same as SOC2. Review who has access to your production database, your admin panels, your third-party consoles. Disable what they don't need. EU regulators care more about this than US ones do.

**Quarter 4 -- Annual policy review.** Update the Privacy Policy if anything material changed. Audit the sub-processor list. Test the breach runbook with a tabletop exercise. By the time you do this in Q4, you have a year of evidence that the program is operational, not just a one-time project.

By month 12 you have a GDPR program that holds up to any EU customer security review, any DPA negotiation, and any data protection authority inquiry. The cost in time was 30 days of focused work in the first month and 2-3 hours per quarter after. The cost in cash was $0-300/yr (mostly the privacy policy generator subscription). The cost in EU revenue lost from not having it is the part that motivated you to read this book in the first place.

---

## Appendix A -- Templates and tools

- **Privacy Policy generator:** iubenda ($27/yr), Termly ($120/yr), or Cookiebot ($12/mo)
- **DPA template:** Most compliance platforms include one. Or use the EU standard contractual clauses (free, `ec.europa.eu/info/law/law-topic/data-protection_en`).
- **Data Flow Diagram tool:** draw.io (free) or Lucidchart
- **ROPA template:** Any spreadsheet with these columns: data category, lawful basis, retention, security measures, sub-processor
- **Cookie consent:** Cookiebot, Osano, or OneTrust

## Appendix B -- The 30-day calendar

| Week | Action | Owner |

|---|---|---|

| 1 | Privacy Policy + DPA published | Founder |

| 2 | Data Flow Diagram + ROPA | Founder + Engineer |

| 3 | Sub-processor DPAs + Breach Runbook | Founder |

| 4 | Test with EU customer persona | Founder |

## Appendix C -- Resources

- GDPR full text (free, `gdpr-info.eu`)
- ICO Guide for Small Businesses (`ico.org.uk/for-organisations/businesses-and-organisations`)

- IAPP (`iapp.org`) -- the trade association, has free resources
- The "GDPR for Indie Hackers" community (`indiehackers.com` search "GDPR")
- Maetzler & Co. plain-English GDPR overview (`lawplainandsimple.com`)
- TermsFeed (`termsfeed.com`) -- free generators for Privacy Policy, Cookie Policy, etc.

## Conclusion

You don't need a DPO to ship GDPR. You need six documents, 30 days, and the discipline to keep them current. The Privacy Policy. The DPA. The data flow diagram. The ROPA. The sub-processor list. The breach runbook. The rest is repetition.

If you ship the 30-day plan and the documentation falls apart within 6 months, you didn't really ship a compliance program -- you shipped a project. The program is the habit. The habit is one quarterly review meeting and one annual policy update.

Either way, GDPR is now a buyer expectation, not a nice-to-have. The SaaS startups that close EU deals in 2026 and beyond are the ones whose founders read a playbook like this on a Tuesday and shipped the program by Friday.

Go ship it.